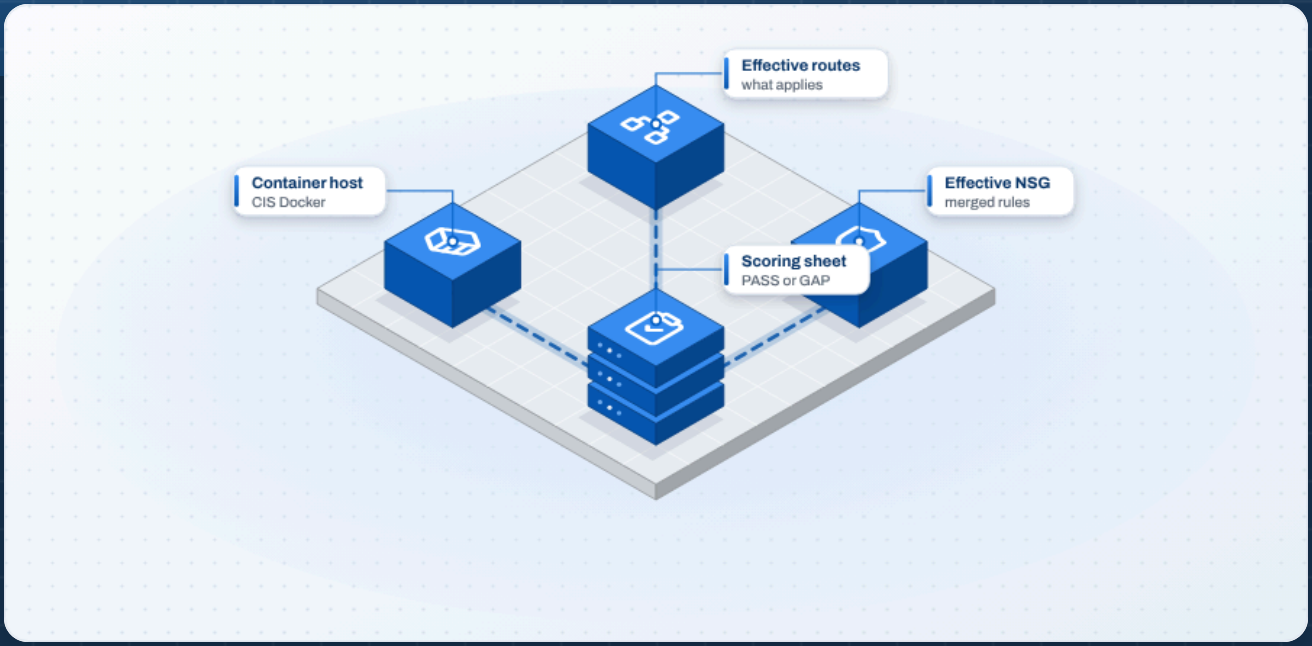
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-AZ-106

Assessing Network Segmentation and Container Hosting

Multi-tenant segmentation, effective routes and NSG rules, public exposure and container host hardening, scored against CIS Azure Foundations and Defender for Cloud.

Cloud Security | NSG | Defender for Cloud



DOCUMENT ID	SOP-AZ-106
VERSION	1.1
EFFECTIVE	October 2026
AUDIENCE	Cloud security engineers, network reviewers, platform engineers
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition · client identifiers removed

Contents

1. Concepts You Need First 2

2. Access, Prerequisites and Planning 3

2.1 Level of access required 3

2.2 Prerequisites checklist 3

3. Procedure in the Azure Portal 4

4. Template · Network Review 7

5. Verification and Troubleshooting 8

5.1 Verify 8

5.2 Troubleshooting 8

6. Summary, Glossary and Review 9

6.1 Chapter summary 9

6.2 Glossary 9

6.3 Framework references 9

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Read what the platform actually enforces with effective routes and effective NSG rules.
- Prove there are no public IPs on workload NICs and no inbound rules open to the internet.
- Score every gap against CIS and Defender for Cloud with a severity and owner role.

CHAPTER 1

Concepts You Need First

An NSG rule on paper is a claim. What reaches a VM is decided by the rules on its subnet and its NIC combined, the routes from its own network, any peering and any user-defined route. Azure computes both views for a running VM; those effective views are the evidence.

KEY CONCEPT · THE MAP VERSUS THE ROAD

The design diagram is the map. Effective routes and effective security rules are the road as it is paved today. Inspect the road.



Figure 1. Read from the NIC outward, merge the findings with Defender and CIS, and score every gap.

Check	Pass when
Public IPs	Only gateways, NAT and Bastion own one; no VM NIC does
Inbound rules	No Allow rule with source Internet, Any or 0.0.0.0/0
Segmentation	Stamps peer only with the hub; no spoke-to-spoke path
Egress	Default route goes where the design says (NAT or firewall)
Container host	Docker socket not on TCP; containers non-root; trusted registry

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

Task	Role	Notes
Read networks and NSGs	Reader at the product root	Effective routes are a read action
Defender recommendations	Security Reader	Defender plans enabled
Docker Bench	Shell on the host, with the client's approval	Runs read-only checks

NOTE · THE VM MUST BE RUNNING

Effective routes and effective security rules are only computed for a running VM. Schedule the review when the VM is up.

2.2 Prerequisites checklist

- [ ] VMs running for the review window.
- [ ] Design document with intended exceptions (NAT and gateway public IPs).
- [ ] Scoring sheet prepared.

CHAPTER 3

Procedure in the Azure Portal

NOTE · HOW THESE SCREENS WERE CAPTURED

Screens in this chapter were captured read-only from a live engagement tenant. Client, product and people names, tenant, subscription and object IDs, email addresses and public IPs are replaced (`org`, `app`, `Contoso`, `00000000-…`, `203.0.113.10`). Compliance figures and unrelated rows are blurred. Portal labels move over time; the setting names are what matter.

STEP 1 Read the inbound rules

1. Open each NSG › **Settings › Inbound security rules.**
2. Every Allow rule should name a narrow source (a subnet, never Internet or Any) and one port.
3. A deny-internet rule should sit above the default rules.

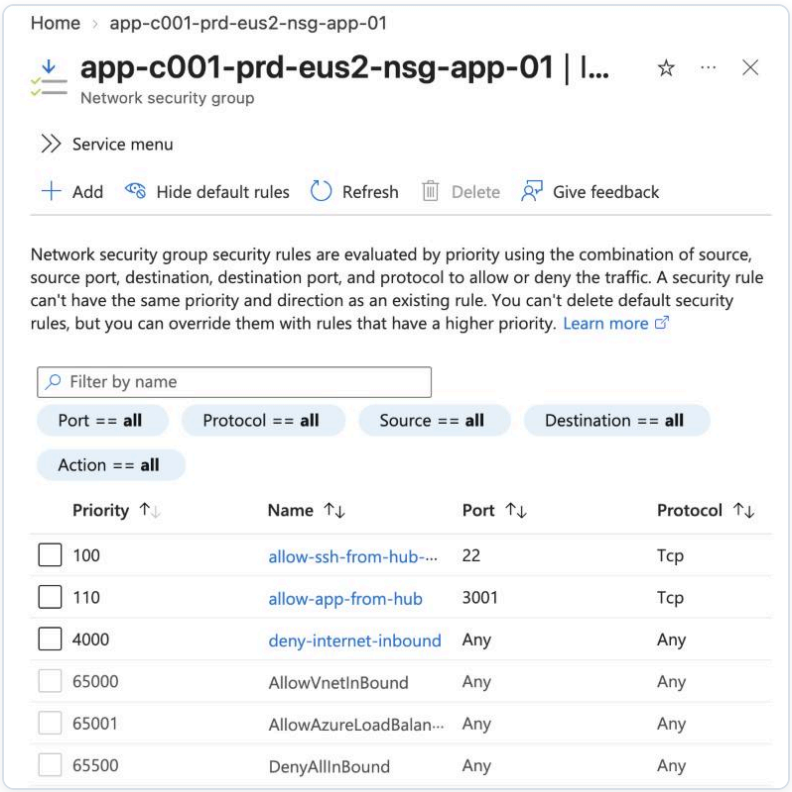


Figure 2. App NSG: SSH from the hub management subnet, the app port from the gateway, and an explicit internet deny at 4000.

STEP 2 Read the effective routes

1. Open the VM's NIC › **Help › Effective routes**.
2. Check the spoke range, the peered hub range and the default route.
3. A `0.0.0.0/0` to Internet means egress leaves through the NAT gateway; if the design calls for a firewall, this row should point to a virtual appliance.

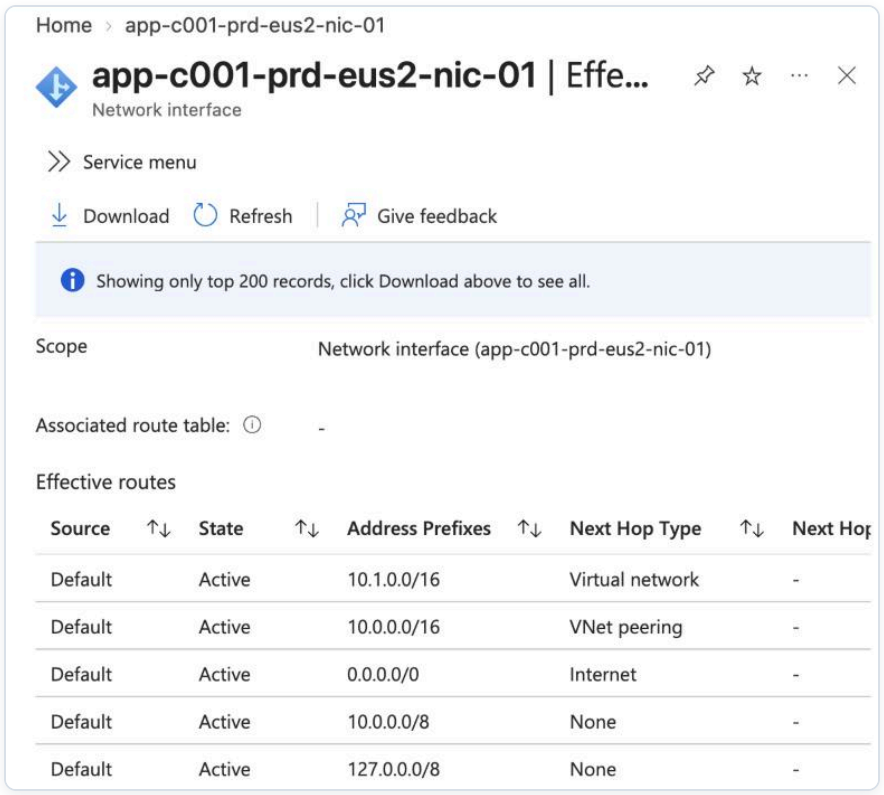


Figure 3. Effective routes on the VM NIC: own VNet, the peered hub, and the default route to the internet through NAT.

> **WHY IT MATTERS · EGRESS IS THE EXFILTRATION PATH**
>
> Outbound 443 to any host is how stolen data leaves. If there is no FQDN allow-list, record it as a finding with the accepted-risk decision.

STEP 3 Read the effective security rules and public exposure

1. On the same NIC open **Effective security rules**; this merges subnet and NIC rules.
2. Open **Public IP addresses** filtered to the product's resource groups; each must belong to a gateway, NAT gateway or Bastion.

STEP 4 Score against CIS and Defender

1. **Microsoft Defender for Cloud › Recommendations** and **Regulatory compliance › CIS Azure Foundations**.
2. Copy every unhealthy item touching network, storage, identity or compute into the scoring sheet with severity and owner role.

STEP 5 Check the container host

1. Run Docker Bench for Security (CIS Docker Benchmark) on the host.
2. Confirm the daemon socket is not exposed over TCP, containers run as non-root, and images come from a trusted registry.

CHAPTER 4

Template · Network Review

SOP-06-NETWORK-REVIEW.PS1 · NETWORK REVIEW · READ ONLY POWERSHELL

```powershell
<#  SOP-06 template: network and container hosting review (read-only).
    Exit criterion: no public IPs on NICs and no inbound rule open to Internet/Any.          #>
param([string]$ResourceGroupLike = '<product>-*', [string]$Out = './network-review')
New-Item -ItemType Directory -Force $Out | Out-Null
$rgs = (Get-AzResourceGroup | Where-Object ResourceGroupName -like $ResourceGroupLike).ResourceGroupName

# 1. Public exposure
Get-AzPublicIpAddress | Where-Object ResourceGroupName -in $rgs |
  Select-Object Name, IpAddress, @{n='Owner';e={($_.IpConfiguration.Id -split '/')[7..8] -join '/'}} | Export-Csv
"$Out/01-public-ips.csv" -NoTypeInformation

# 2. Inbound rules open to the world
Get-AzNetworkSecurityGroup | Where-Object ResourceGroupName -in $rgs | ForEach-Object {
  $n = $_.Name
  $_.SecurityRules | Where-Object { $_.Direction -eq 'Inbound' -and $_.Access -eq 'Allow' -and
                                    ($_.SourceAddressPrefix -in '*','Internet','0.0.0.0/0') } |
    Select-Object @{n='Nsg';e={$n}}, Name, Priority, DestinationPortRange
} | Export-Csv "$Out/02-open-inbound.csv" -NoTypeInformation

# 3. Effective routes and effective NSG per VM NIC (what the platform actually enforces)
Get-AzNetworkInterface | Where-Object ResourceGroupName -in $rgs | ForEach-Object {
  Get-AzEffectiveRouteTable -NetworkInterfaceName $_.Name -ResourceGroupName $_.ResourceGroupName |
    Select-Object Source, State, @{n='Prefix';e={$_.AddressPrefix -join ','}}, NextHopType | Export-Csv "$Out/03-
routes-$($_.Name).csv" -NoTypeInformation
  Get-AzEffectiveNetworkSecurityGroup -NetworkInterfaceName $_.Name -ResourceGroupName $_.ResourceGroupName |
    ConvertTo-Json -Depth 8 | Set-Content "$Out/04-effective-nsg-$($_.Name).json"
}

# 4. Defender for Cloud: secure score and unhealthy recommendations (CIS-mapped)
Get-AzSecuritySecureScore | Select-Object DisplayName, @{n='Pct';e={[math]::Round($_.Percentage*100)}}
Get-AzSecurityAssessment | Where-Object { $_.Status.Code -eq 'Unhealthy' } |
  Select-Object DisplayName, @{n='Resource';e={($_.Id -split '/providers/Microsoft.Security')[0] -replace
'.*/',''}} |
  Export-Csv "$Out/05-defender-unhealthy.csv" -NoTypeInformation

# 5. Container host (Docker on a VM): run on the host, CIS Docker Benchmark
#   docker run --rm --net host --pid host --cap-add audit_control -v /var/run/docker.sock:/var/run/docker.sock:ro
\
#     -v /etc:/etc:ro docker/docker-bench-security > docker-bench.txt
```

CHAPTER 5

Verification and Troubleshooting

5.1 Verify

- [ ] `01-public-ips.csv` lists only gateway, NAT or Bastion owners.
- [ ] `02-open-inbound.csv` is empty.
- [ ] Effective route and NSG exports exist for every VM NIC and are hashed.
- [ ] Every Defender or CIS gap has a score and an owner role.

5.2 Troubleshooting

Symptom	Likely cause and fix
Effective routes stay on Loading	VM is deallocated. Start it or review when it runs.
Public IP on a NIC despite the policy	Created before the policy, or an exemption exists. Check the assignment exemptions.
Defender shows no recommendations	Plans not enabled or the scan has not run yet. Allow 24 hours after enabling.

CHAPTER 6

Summary, Glossary and Review

6.1 Chapter summary

- Effective views are the evidence; rules on paper are claims.
- No public IP on a NIC, no inbound from the internet, stamps isolated from each other.
- Every gap scored with severity and owner role.

Check your understanding

1. Why read effective security rules instead of the NSG alone?
2. What does a 0.0.0.0/0 route to Internet tell you?
3. Which resources may legitimately own a public IP?

6.2 Glossary

Effective routes	The route table Azure actually applies to a NIC.
NSG	Network security group: allow and deny rules for subnets and NICs.
Secure score	Defender for Cloud measure of how many recommendations are met.

6.3 Framework references

Framework	Controls
CIS Azure Foundations	6.x, 7.x
NIST SP 800-53 R5	SC-7, SC-7(5), CM-7, AC-4
ISO/IEC 27001:2022	A.8.20, A.8.22
PCI DSS v4 (boundary)	1.3, 1.4